

S BHANU PRAKASH

Cybersecurity Enthusiast — Ethical Hacking & VAPT Practice

Vulnerability Assessment & Penetration Test Report

Black-Box Network & Web Application Assessment — bWAPP bee-box

Target	bWAPP bee-box (buggy web application VM)
Target Host	192.168.1.17 (isolated internal lab network)
Assessment Type	Black-box network & web application vulnerability assessment
Prepared By	S Bhanu Prakash
Assessment Dates	13 – 14 July 2026
Purpose	Independent practice — automated scanning, SNMP/SMB enumeration, and manual triage

Note: This assessment was carried out in an isolated personal/virtual lab environment against intentionally vulnerable practice systems, as part of independent cybersecurity skill-building. No production systems, third-party assets, or real organizations were involved or affected.

1. Executive Summary

As an independent lab exercise, I performed a black-box vulnerability assessment and penetration test against 192.168.1.17, an instance of bWAPP bee-box — a deliberately vulnerable Linux VM used for security training and tool practice. The assessment simulates the perspective of an unauthenticated attacker with network access to the target.

The exercise combined automated vulnerability scanning (Nuclei v3.11.0), SNMP enumeration (snmpwalk), and SMB/NetBIOS enumeration (smbclient, enum4linux) to identify exposed services, misconfigurations, and exploitable vulnerabilities. A total of 48 distinct findings were confirmed by the automated scan, supplemented by manual verification of the SNMP and SMB exposures.

Two Critical-severity issues were identified — an unauthenticated remote code execution vulnerability in the DistCC daemon (CVE-2004-2687) and a publicly readable SNMP community string that discloses the complete process table, running services, and configuration of the host. Combined with numerous end-of-life software components (Apache 2.2.8, PHP 5.2.4, Samba 3.0.28a, OpenSSH 4.7p1), these give an attacker a very high likelihood of full remote compromise with minimal effort.

Overall Risk Rating: CRITICAL

2. Findings Distribution by Severity

Severity	Count
Critical	2
High	4
Medium	6
Low	8
Informational	28

Figure 1: Findings by severity (Nuclei automated scan results, 48 total).

3. Scope and Methodology

3.1 Scope

Field	Detail
In-Scope Target	192.168.1.17 (single host, all TCP/UDP ports)
Application	bWAPP bee-box — buggy web application VM
Testing Type	Black-box, unauthenticated, network + web application

3.2 Methodology

- Automated vulnerability scanning using Nuclei v3.11.0 with the full public template repository (v10.4.5, 10,447 templates).
- SNMP enumeration using snmpwalk with the default community string "public" (v1).
- SMB/NetBIOS share and user enumeration using smbclient and enum4linux, including RID cycling.
- Manual verification and triage of all automated findings to remove false positives and confirm exploitability.
- Risk rating applied on a Critical / High / Medium / Low / Informational scale based on exploitability and impact.

3.3 Tools Used

Tool	Purpose
Nuclei v3.11.0	Automated template-based vulnerability scanner (10,447 templates)
snmpwalk (net-snmp)	SNMPv1/v3 enumeration
smbclient / enum4linux v0.9.1	SMB share and user enumeration

4. Findings Summary

#	Finding	Severity	Component / Location
1	Unauthenticated DistCC Daemon RCE (CVE-2004-2687)	Critical	distccd (TCP/3632)
2	SNMP Community String Disclosure ("public") with Full System Enumeration	Critical	SNMP (UDP/161)
3	Samba 3.0.28a / SMBv1 with Anonymous (NULL) Session Access	High	Samba (TCP/445)
4	Outdated Apache 2.2.8 and PHP 5.2.4 (End-of-Life)	High	Apache/PHP (TCP/80)
5	Exposed SQLite Web Manager Interface	High	HTTP /sqlite/
6	Weak / Deprecated SSH Cryptographic Configuration	High	SSH (TCP/22)
7	Apache mod_status Information Disclosure	Medium	HTTP /server-status
8	phpMyAdmin Panel Exposed to Unauthenticated Access	Medium	HTTP /phpmyadmin/
9	Backup / Sensitive File Exposure via Content Negotiation	Medium	HTTP /index
10	Missing HTTP Security Headers (CSP, HSTS, X-Frame-Options, etc.)	Medium	HTTP/HTTPS
11	RID Cycling Enables Full Local User Enumeration	Medium	SMB / RPC (TCP/445)
12	HTTP TRACE / OPTIONS Methods Enabled	Medium	HTTP (TCP/80)
13	MySQL, VNC and rlogin Services Exposed to Network	Low	TCP/3306, 5901, 513
14	Verbose Software Banners Disclosed	Low	Multiple

5. Detailed Findings

[CRITICAL] Unauthenticated DistCC Remote Code Execution (CVE-2004-2687)

Affected: distccd on TCP/3632 | CVSS: 9.8 (est.)

Nuclei confirmed a DistCC daemon listening on TCP/3632. DistCC's distributed compilation service, when exposed without access controls, allows any reachable client to submit arbitrary compilation jobs — historically leveraged to achieve remote command execution as the user running the daemon (confirmed as root here via SNMP process enumeration: "--user root --daemon").

Recommendation

- Immediately disable or firewall the DistCC service from all untrusted networks.
- If distributed compilation is required, restrict access via VPN/allow-list and run the daemon under a non-privileged, sandboxed account.

[CRITICAL] SNMP Community String Disclosure and Full System Enumeration

Affected: SNMP (UDP/161), community string "public" (SNMPv1)

The SNMP service accepted the default community string "public" for SNMPv1 queries. A full snmpwalk returned complete system information: kernel version and boot parameters, network interface and routing configuration, and — most critically — the full running process list with command-line arguments, disclosing the VNC password file path (/root/.vnc/passwd), MySQL startup parameters, and confirmation that distccd and VNC run as root.

Recommendation

- Disable SNMPv1/v2c or restrict to non-default, read-only community strings.
- Migrate to SNMPv3 with authentication and encryption.
- Restrict SNMP access via firewall to authorized management hosts only.

[HIGH] Samba 3.0.28a with SMBv1 and Anonymous Access

Affected: Samba (TCP/445, TCP/139), version 3.0.28a (end-of-life)

The target runs Samba 3.0.28a with multiple publicly known vulnerabilities and continues to support the deprecated, inherently insecure SMBv1 protocol. Anonymous (NULL session) access was permitted, allowing unauthenticated enumeration of shares (including a writable "tmp" share), the domain name (ITSECGAMES), local user accounts, and full RID cycling of users/groups via enum4linux.

Recommendation

- Upgrade Samba to a currently supported release.
- Disable SMBv1 entirely; disable anonymous/NULL session access.
- Enforce SMB signing and least-privilege share permissions.

[HIGH] Outdated Apache 2.2.8 and PHP 5.2.4 (End-of-Life)

Affected: Apache HTTP Server (TCP/80) — Apache/2.2.8, PHP/5.2.4-2ubuntu5, OpenSSL/0.9.8g

The web server banner discloses Apache 2.2.8, PHP 5.2.4, and OpenSSL 0.9.8g — all long past end-of-life and unpatched against numerous publicly documented vulnerabilities, including remote code execution and denial-of-service issues. Verbose banner disclosure also aids attacker reconnaissance.

Recommendation

- Upgrade the full web stack (OS, Apache, PHP, OpenSSL) to currently supported, patched versions.
- Suppress version banners via ServerTokens/ServerSignature and PHP's expose_php directive.

[HIGH] Exposed SQLite Web Management Interface

Affected: http://192.168.1.17/sqlite/

Nuclei identified an exposed SQLite web-based database management interface. Such consoles, when accessible without authentication, commonly allow arbitrary SQL execution, file read/write, and in several known implementations, remote code execution via crafted database functions.

Recommendation

- Remove or restrict access to the SQLite manager to trusted administrative networks only.
- Enforce strong authentication if the tool must remain available.

[HIGH] Weak SSH Cryptographic Configuration

Affected: OpenSSH 4.7p1 Debian-8ubuntu1 (TCP/22)

The SSH service supports the Logjam-vulnerable Diffie-Hellman group exchange, CBC-mode ciphers, SHA-1 HMAC algorithms, and other weak/deprecated cryptographic settings. The OpenSSH version itself is significantly outdated.

Recommendation

- Upgrade OpenSSH to a current release.
- Disable weak KEX/cipher/MAC algorithms (CBC ciphers, SHA-1 HMACs, small DH groups).
- Enforce key-based authentication.

[MEDIUM] Additional Web Application and Infrastructure Findings

- Apache mod_status exposed at /server-status, disclosing internal request details, client IPs, and server load in real time.
- phpMyAdmin panel accessible at /phpmyadmin/ without evidence of IP restriction or additional authentication gating.
- Apache content-negotiation misconfiguration exposes backup/alternate files such as index.bak alongside index.html.
- Missing security headers across all responses: CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.
- HTTP TRACE and OPTIONS methods enabled, which can facilitate Cross-Site Tracing (XST) style attacks in conjunction with client-side vulnerabilities.
- RID cycling against SMB successfully enumerated seven local OS-level user accounts without authentication.

Recommendation: Restrict /server-status and /phpmyadmin/ to trusted source IPs or place behind authentication; remove backup files from the web root; deploy standard security headers; disable TRACE/TRACK methods; harden SMB against anonymous enumeration.

[LOW / INFO] Additional Exposed Services and Banner Disclosure

- MySQL 5.0.96-0ubuntu3, VNC (Xvnc), and rlogin services exposed directly to the network on TCP/3306, TCP/5901, and TCP/513 respectively.
- Verbose version banners disclosed across HTTP, SSH, SMTP, NTP, and SNMP services, aiding attacker fingerprinting.
- NetBIOS name service and workgroup information (ITSECGAMES) broadcast over UDP/137.

Recommendation: Restrict database, remote-access, and legacy protocol services to internal management networks only; disable rlogin entirely in favor of SSH; suppress unnecessary service banners where feasible.

6. Identified Open Ports and Services

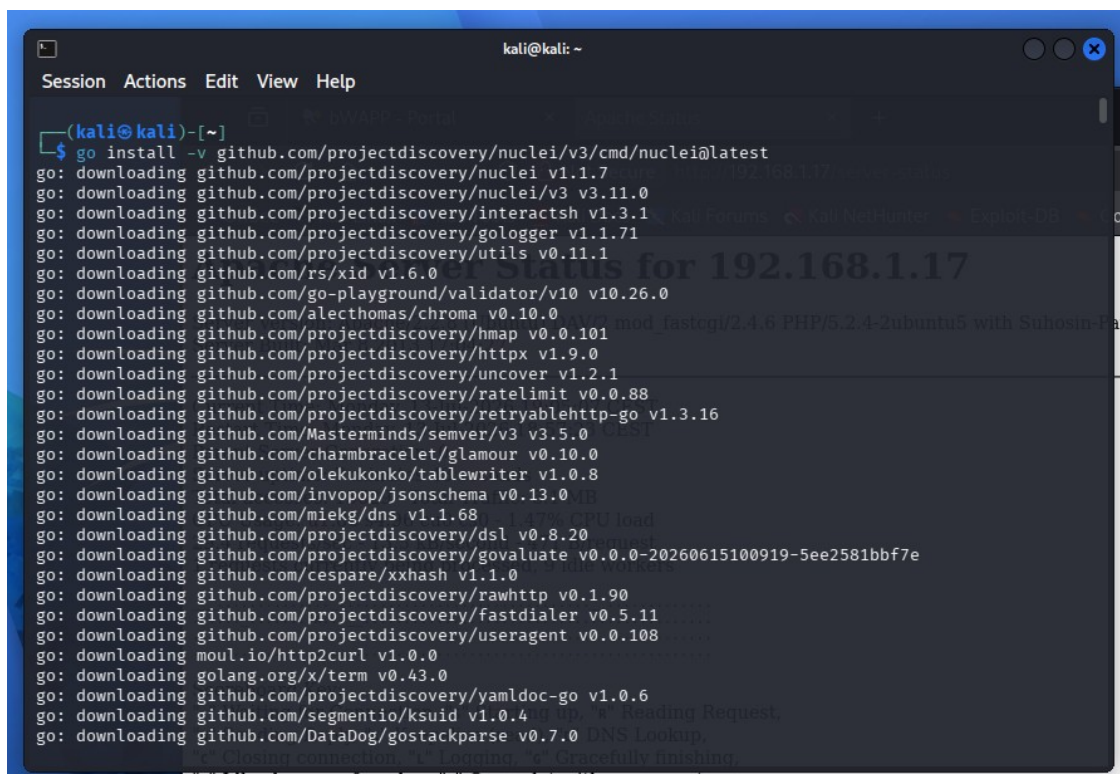
Port	Proto	Service	Version / Details
22	tcp	SSH	OpenSSH 4.7p1 Debian-8ubuntu1 — weak algorithms
25	tcp	SMTP	Postfix — ESMTP, STARTTLS supported
80	tcp	HTTP	Apache/2.2.8, PHP/5.2.4, mod_fastcgi, DAV/2
123	udp	NTP	ntpd 4.2.4p4 — variables enumeration enabled
137	udp	NetBIOS-NS	Workgroup ITSECGAMES disclosed
161	udp	SNMP	net-snmp — community string "public" (v1)
445	tcp	SMB	Samba 3.0.28a — SMBv1, anonymous access
513	tcp	rlogin	Legacy remote login service detected
3306	tcp	MySQL	Version 5.0.96-0ubuntu3

Port	Proto	Service	Version / Details
3632	tcp	distccd	CVE-2004-2687 — unauthenticated RCE
5901	tcp	VNC	Xvnc — remote desktop access

Additional ports were referenced within SNMP process/route tables (e.g. 21, 6001, 8080, 8443, 9080, 9443) and would be independently verified with a full TCP/UDP port sweep as part of remediation validation.

7. Evidence and Screenshots

7.1 Nuclei Template Installation and Tool Setup



```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ go install -v github.com/projectdiscovery/nuclei/v3/cmd/nuclei@latest
go: downloading github.com/projectdiscovery/nuclei v1.1.7
go: downloading github.com/projectdiscovery/nuclei/v3 v3.11.0
go: downloading github.com/projectdiscovery/interactsh v1.3.1
go: downloading github.com/projectdiscovery/gologger v1.1.71
go: downloading github.com/projectdiscovery/utils v0.11.1
go: downloading github.com/rs/xid v1.6.0
go: downloading github.com/go-playground/validator/v10 v10.26.0
go: downloading github.com/alecthomas/chroma v0.10.0
go: downloading github.com/projectdiscovery/hmap v0.0.101
go: downloading github.com/projectdiscovery/httpx v1.9.0
go: downloading github.com/projectdiscovery/uncover v1.2.1
go: downloading github.com/projectdiscovery/ratelimit v0.0.88
go: downloading github.com/projectdiscovery/retryablehttp-go v1.3.16
go: downloading github.com/Masterminds/semver/v3 v3.5.0
go: downloading github.com/charmbracelet/glamour v0.10.0
go: downloading github.com/olekukonko/tablewriter v1.0.8
go: downloading github.com/involopop/jsonschema v0.13.0
go: downloading github.com/miekg/dns v1.1.68
go: downloading github.com/projectdiscovery/dsl v0.8.20
go: downloading github.com/projectdiscovery/govaluate v0.0.0-20260615100919-5ee2581bbf7e
go: downloading github.com/cespare/xxhash v1.1.0
go: downloading github.com/projectdiscovery/rawhttp v0.1.90
go: downloading github.com/projectdiscovery/fastdialer v0.5.11
go: downloading github.com/projectdiscovery/useragent v0.0.108
go: downloading moul.io/http2curl v1.0.0
go: downloading golang.org/x/term v0.43.0
go: downloading github.com/projectdiscovery/yamldoc-go v1.0.6
go: downloading github.com/segmentio/ksuid v1.0.4
go: downloading github.com/DataDog/gostackparse v0.7.0

```

Figure 2: Installing the Nuclei engine and template repository.

7.2 Nuclei CLI Help and Target Configuration

```

kali@kali: ~
Session Actions Edit View Help
github.com/projectdiscovery/nuclei/v3/internal/server
github.com/projectdiscovery/nuclei/v3/internal/runner
github.com/projectdiscovery/nuclei/v3/cmd/nuclei

(kali@kali)-[~]
$ nuclei -h
Nuclei is a fast, template based vulnerability scanner focusing
on extensive configurability, massive extensibility and ease of use.

Usage:
  nuclei [flags]

Flags:
  -u, -target string[]      target URLs/hosts to scan
  -l, -list string          path to file containing a list of target URLs/hosts to scan (one per line)
  -e, -targets-inline string inline multiline target list (for use in template profiles)
  -eh, -exclude-hosts string[] hosts to exclude to scan from the input list (ip, cidr, hostname)
  -resume string            resume scan from and save to specified file (clustering will be disabled)
  -sa, -scan-all-ips        scan all the IP's associated with dns record
  -iv, -ip-version string[] IP version to scan of hostname (4,6) - (default 4)

TARGET-FORMAT:
  -im, -input-mode string   mode of input file (list, burp, jsonl, yaml, openapi, swagger) (default "list")
  -ro, -required-only       use only required fields in input format when generating requests
  -sfv, -skip-format-validation skip format validation (like missing vars) when parsing input file
  -vtt, -vars-text-templating enable text templating for vars in input file (only for yaml input mode)
  -vfp, -var-file-paths string[] list of yaml file contained vars to inject into yaml input

```

Figure 3: Nuclei command-line usage reference.

7.3 Initial Nuclei Scan Execution Against the Target

```

kali@kali: ~
Session Actions Edit View Help
Run nuclei with sorted Markdown outputs (with environment variables):
  $ MARKDOWN_EXPORT_SORT_MODE=template nuclei -target example.com -markdown-export nuclei_report/

Additional documentation is available at: https://docs.nuclei.sh/getting-started/running

(kali@kali)-[~]
$ nuclei -target http://192.168.1.17/

Apache Server Status for 192.168.1.17
Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch
Server Built: Mar 8 2013 17:04:27
projectdiscovery.io
v3.11.0

[INF] nuclei-templates are not installed, installing...
[INF] Successfully installed nuclei-templates at /home/kali/nuclei-templates
[INF] Current nuclei version: v3.11.0 (latest)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 10447
[INF] Executing 10430 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Templates clustered: 2389 (Reduced 2256 Requests)
[INF] Using Interactsh Server: oast.live
[phpmyadmin-panel] [http] [info] http://192.168.1.17/phpmyadmin/ [paths="/phpmyadmin/"]
[http-trace:trace-request] [http] [info] http://192.168.1.17/
[http-trace:options-request] [http] [info] http://192.168.1.17/
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://192.168.1.17/index ["index.bak", "index.html"] [path="/index"]
[waf-detect:apachegeneric] [http] [info] http://192.168.1.17/ finishing
[samba-detect] [javascript] [info] 192.168.1.17:445 ["Samba 3.0.28a"]
[ssh-auth-methods] [javascript] [info] 192.168.1.17:22 [{"publickey", "password"}]
[rlogin-detect] [javascript] [info] 192.168.1.17:513
[mysql-info] [javascript] [info] 192.168.1.17:3306 ["Version: 5.0.96-0ubuntu3", "Transport: tcp"]
[ntlm-info] [javascript] [info] 192.168.1.17:445 ["NTLM: Samba 3.0.28a"]
[smb-v1-supported] [javascript] [info] 192.168.1.17:445 0.04 0.59 192.168.1.9 bee-box GET /wp-content/plugins/

```

Figure 4: Nuclei scan startup and initial findings including SNMP and SMB detections.

7.4 Apache mod_status and SNMP Enumeration Output

```

Session Actions Edit View Help
[apache-server-status] [http] [low] http://192.168.1.17/server-status
[INF] Scan completed in 2m. 48 matches found.
[INF] HTTP connections: 13236 total, 1753 new, 11483 reused (86.8%)

(kali@kali)-[~]
$ snmpwalk -v1 -c public 192.168.1.17
iso.3.6.1.2.1.1.1.0 = STRING: "Linux bee-box 2.6.24-16-generic #1 SMP Thu Apr 10 13:23:42 UTC 2008 i686"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (38533) 0:06:25.33
iso.3.6.1.2.1.1.4.0 = STRING: "Your master bee"
iso.3.6.1.2.1.1.5.0 = STRING: "bee-box"
iso.3.6.1.2.1.1.6.0 = STRING: "Every bee needs a home!"
iso.3.6.1.2.1.1.8.0 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and Dispatching."
iso.3.6.1.2.1.1.9.1.3.3 = STRING: "The management information definitions for the SNMP User-based Security Model."
iso.3.6.1.2.1.1.9.1.3.4 = STRING: "The MIB module for SNMPv2 entities"
iso.3.6.1.2.1.1.9.1.3.5 = STRING: "The MIB module for managing TCP implementations"
iso.3.6.1.2.1.1.9.1.3.6 = STRING: "The MIB module for managing IP and ICMP implementations"
iso.3.6.1.2.1.1.9.1.3.7 = STRING: "The MIB module for managing UDP implementations"
iso.3.6.1.2.1.1.9.1.3.8 = STRING: "View-based Access Control Model for SNMP."
iso.3.6.1.2.1.1.9.1.4.1 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.2 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.3 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.4 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.5 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.6 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.7 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.1.9.1.4.8 = Timeticks: (0) 0:00:00.00
iso.3.6.1.2.1.2.1.0 = INTEGER: 2

```

Figure 5: Apache server-status disclosure and beginning of SNMP walk output.

7.5 Extended SNMP Process Table Enumeration

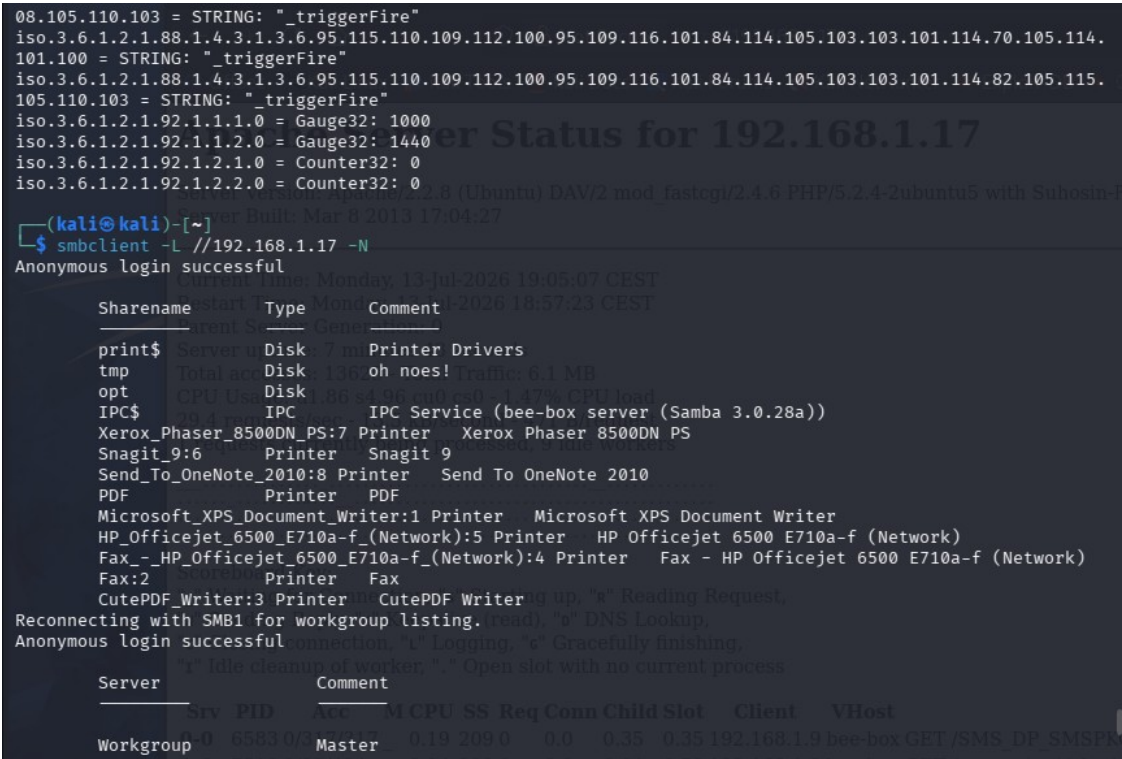


Figure 6: SNMP walk revealing running processes, including root-owned services.

7.6 SMB Share and User Enumeration

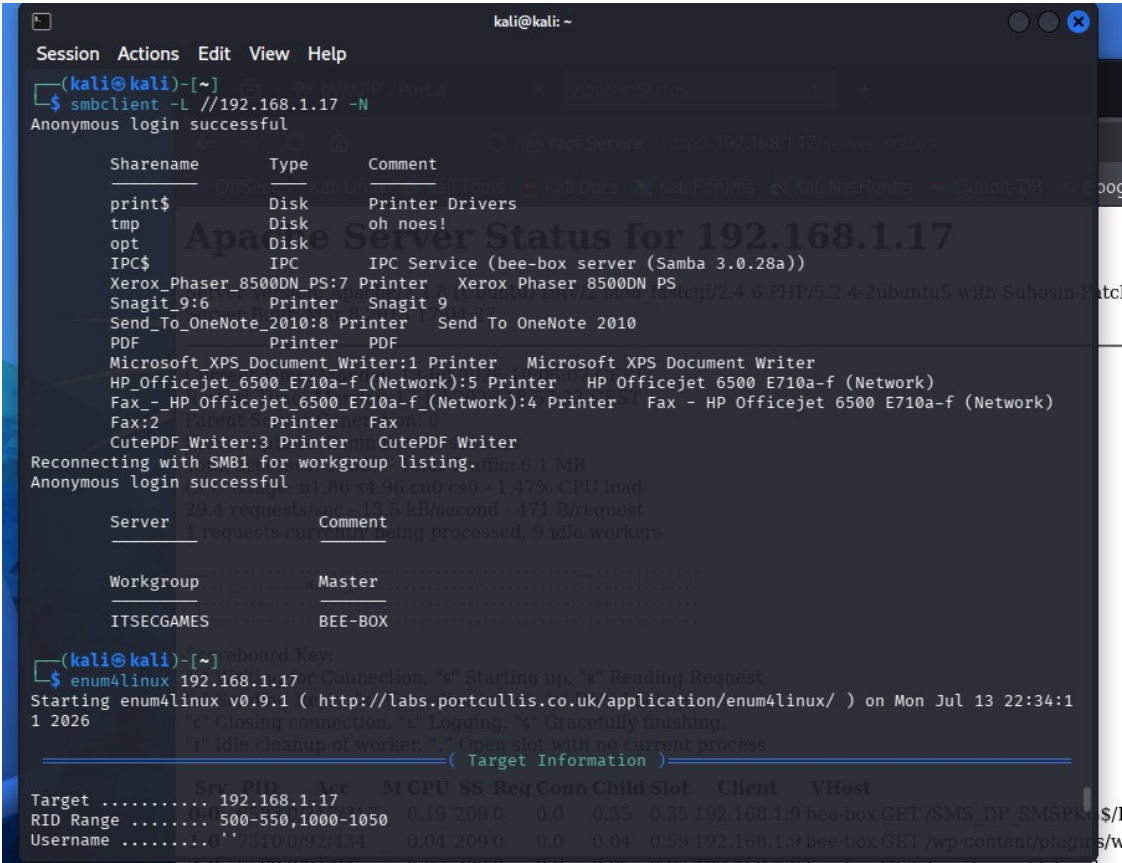
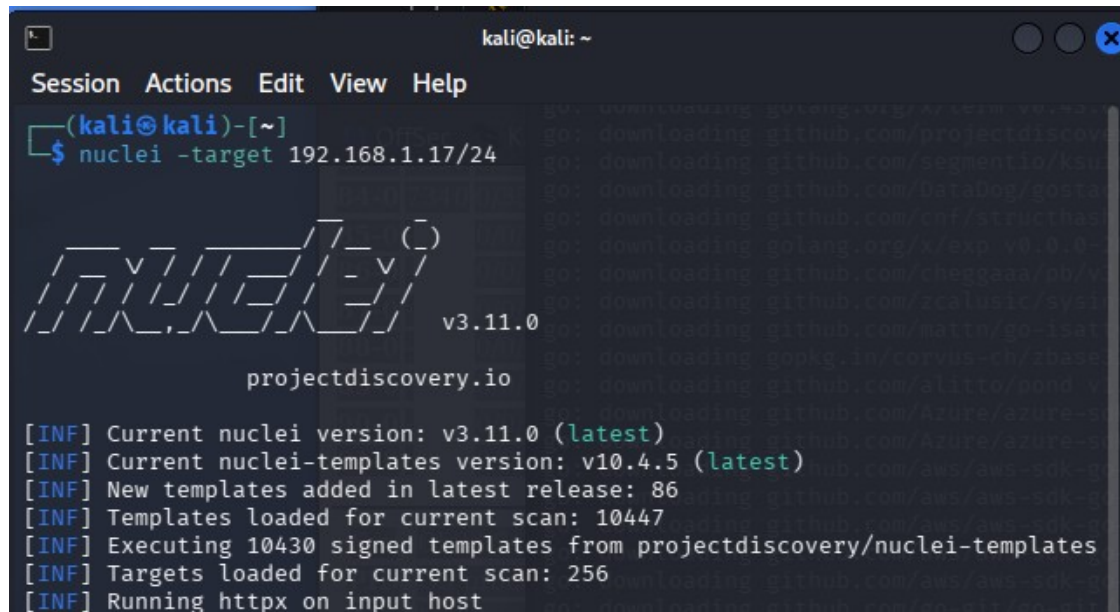


Figure 7: smbclient share listing and enum4linux domain/user enumeration output.

7.7 Network-Wide Nuclei Scan



```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ nuclei -target 192.168.1.17/24

projectdiscovery.io v3.11.0

[INF] Current nuclei version: v3.11.0 (latest)
[INF] Current nuclei-templates version: v10.4.5 (latest)
[INF] New templates added in latest release: 86
[INF] Templates loaded for current scan: 10447
[INF] Executing 10430 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 256
[INF] Running httpx on input host
  
```

Figure 8: Supplementary Nuclei scan across the /24 lab subnet including the target host.

8. Risk Rating Methodology

Rating	Meaning
Critical	Unauthenticated remote code execution or full system compromise achievable with minimal effort.
High	Significant exposure of sensitive data/credentials, or high likelihood of exploitation leading to compromise.
Medium	Exploitable but requires additional conditions, chained vulnerabilities, or has limited direct impact.
Low	Minor exposure or hardening opportunity with limited standalone impact.

9. Conclusion and Overall Recommendations

The bWAPP bee-box host at 192.168.1.17 exhibits a very high number of critical and high-severity exposures, consistent with its purpose as an intentionally vulnerable training platform. If this configuration were replicated on a production system, an attacker would very likely achieve full remote compromise within minutes via the unauthenticated DistCC service, with SNMP disclosure providing further reconnaissance for lateral movement.

- Immediately isolate this host from untrusted networks or decommission the DistCC and SNMP (public community) services.
- Patch or replace all end-of-life software components (OS, Apache, PHP, OpenSSL, Samba, OpenSSH).
- Disable SMBv1, anonymous SMB sessions, and enforce SMB signing.
- Remove or restrict administrative interfaces (phpMyAdmin, SQLite Manager, mod_status) to trusted management networks.
- Implement standard HTTP security headers and disable unnecessary HTTP methods (TRACE).
- Conduct a follow-up validation assessment after remediation to confirm all findings are resolved.

What I practiced in this exercise

- Running and interpreting large-scale template-based scanning with Nuclei across thousands of checks.
- Using snmpwalk and enum4linux/smbclient for protocol-specific enumeration beyond what a generic scanner reports.
- Correlating findings across tools (e.g. SNMP process data confirming DistCC and VNC run as root) to build a fuller picture of impact.
- Structuring a full VAPT report: executive summary, methodology, risk-rated findings, and prioritized remediation.